

《信息系统安全》第五讲

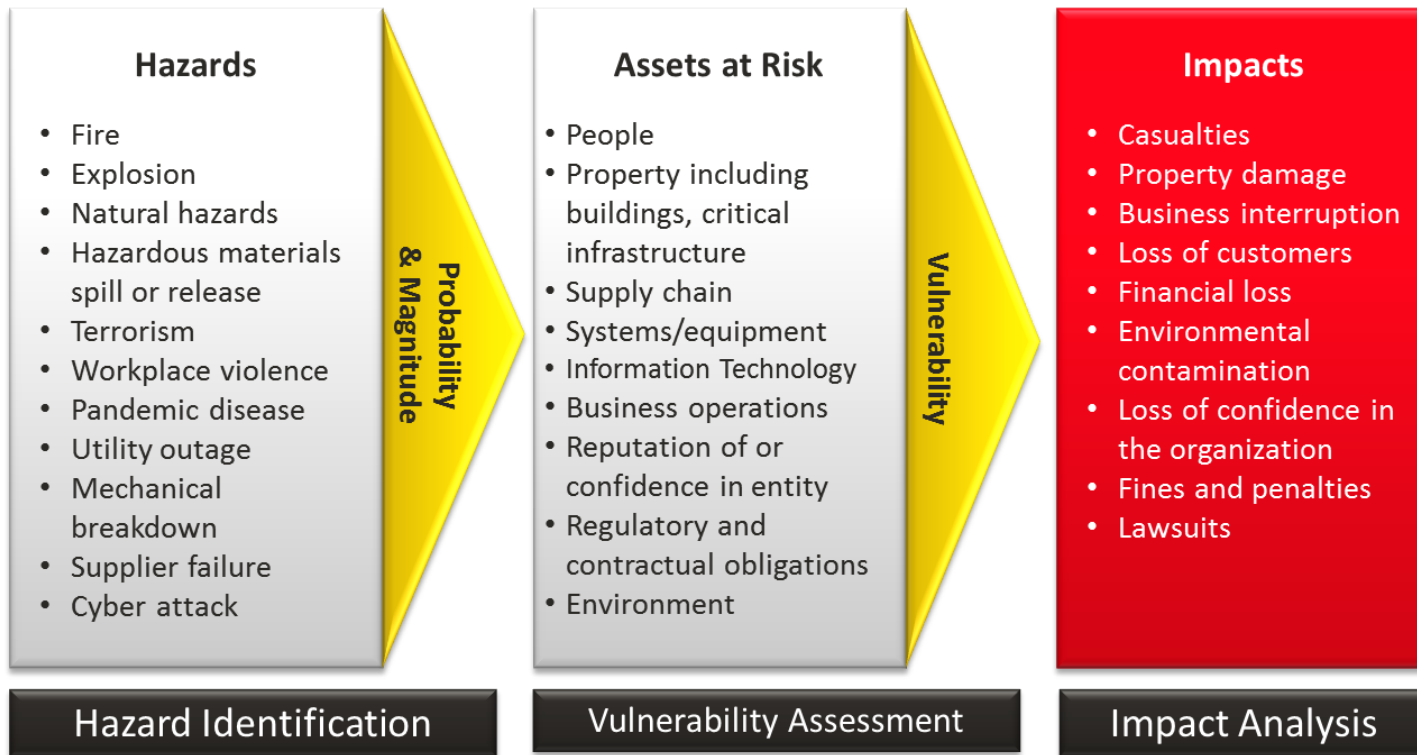
# 信息系统等级保护

2024年10月29日

周亚建

yajian@bupt.edu.cn

# Overview of Last Class



把残余风险控制在可接受的范围内

# 习近平在网络安全与信息化工作座谈会上的讲话



信息技术变化越来越快，过去分散独立的网络变得高度关联、相互依赖，网络安全的威胁来源和攻击手段不断变化，**那种依靠装几个安全设备和安全软件就想永保安全的想法已不合时宜，需要树立动态、综合的防护理念。**



金融、能源、电力、通信、交通等领域的关键信息基础设施是经济社会运行的神经中枢，是网络安全的中中之重，也是可能遭到重点攻击的目标。.....**我们必须深入研究，采取有效措施，切实做好国家关键信息基础设施安全防护。**



（要）**全天候全方位感知网络安全态势。**知己知彼，才能百战不殆。**没有意识到风险是最大的风险。**网络安全具有很强的隐蔽性，一个技术漏洞、安全风险可能隐藏几年都发现不了，结果是“谁进来了不知道、是敌是友不知道、干了什么不知道”，长期“潜伏”在里面，一旦有事就发作了。



**要建立政府和企业网络安全信息共享机制**，把企业掌握的大量网络安全信息用起来，龙头企业要带头参加这个机制。



# 网络安全法解读

---

一法一决定，有法可依，有法必依， .....

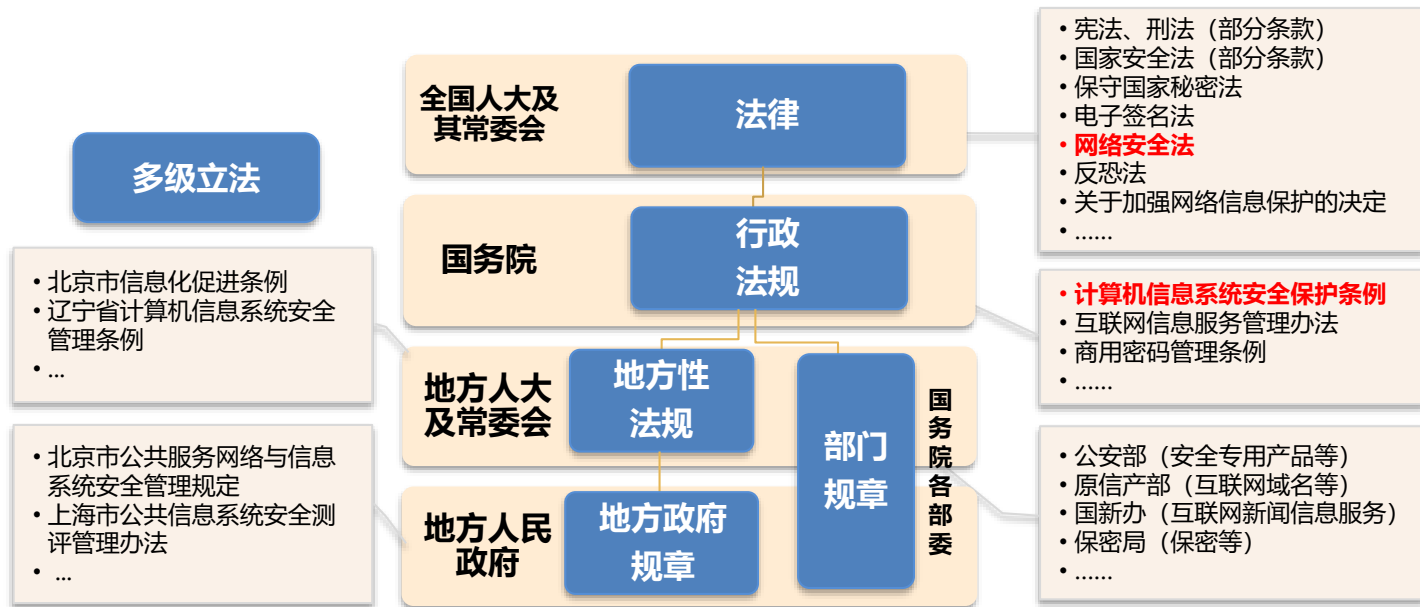
# 网络安全法解读——网络安全法整体框架

## “防御、控制与惩治” 三位一体 **7章79条**



|                   |       |                          |
|-------------------|-------|--------------------------|
| 第一章 总则            | 14条规定 | 简述法律目的，范围，总则，部门职责，总体要求等  |
| 第二章 网络安全支持与促进     | 6条规定  | 定义国家直属部门、政府在推动网络安全工作上的职责 |
| 第三章 网络运行安全        | 19条规定 | 定义网络运营者与关键信息基础设施的运行安全规定  |
| 第一节 一般规定          | 10条规定 | 针对网络运营者的网络运行安全要求与职责规定    |
| 第二节 关键信息基础设施的运行安全 | 9条规定  | 针对关键信息基础设施的安全规定与保护措施要求   |
| 第四章 网络信息安全        | 11条规定 | 定义个人信息保护的保护规定            |
| 第五章 监测预警与应急处置     | 8条规定  | 定义国家网络安全监测预警与汇报机制        |
| 第六章 法律责任          | 17条规定 | 定义处罚规定                   |
| 第七章 附则            | 4条规定  | 相关名词释义与其他附则              |

# 《网络安全法》是网络安全领域的基本法



# 网络安全法解读（续）

| 章节            | 核心内容解读                                                                                                                                                                                                    |
|---------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 第三章<br>网络运行安全 | <p>第一节：</p> <ul style="list-style-type: none"><li>● 国家实行网络安全<b>等级保护制度</b>（第二十一条）</li><li>● 网络产品、服务应当符合相关国家标准的<b>强制性要求</b></li><li>● 网络关键设备和产品应强制取得<b>国家安全标准认证</b></li><li>● 对网络运营者提共标准的安全职责工作说明</li></ul> |
|               | <p>第二节：</p> <ul style="list-style-type: none"><li>● 针对<b>公共通信和信息服务、能源、交通、水利、金融、公共服务、电子政务</b>等重要行业和领域，在网络安全<b>等级保护制度</b>的基础上，实行<b>重点保护</b></li><li>● 每年至少进行一次检测评估</li><li>● 定期组织安全应急演练</li></ul>           |

**安全等保上升到法律高度，不做等保防护，是属违法！**

## 网络安全法解读（续）

| 章节               | 核心内容解读                                                                                             |
|------------------|----------------------------------------------------------------------------------------------------|
| 第四章<br>网络信息安全    | 个人隐私保护、发布信息监管                                                                                      |
| 第五章<br>监测预警与应急处置 | <b>信息通报制度上升为法律</b><br>网络安全预警监测、安全风险评估、应急预案、风险发布                                                    |
| <b>第六章 法律责任</b>  | 最高 <b>100万</b> ：违反22/27/33/34/36/38/41/42/43，最高100万，主管10万<br>最高 <b>50万</b> ：违反22/24/27/37/46/47/69 |

等保1.0时代的最高国家政策是《中华人民共和国计算机信息系统安全保护条例（国务院147号令）》，而等保2.0时代的最高国家政策是《中华人民共和国网络安全法》。等保2.0实施后，不开展等级保护等于违反《网络安全法》，可以根据法律规定进行处罚。



# 网络安全法解读（续）

## 事件4：山西省直事业单位网站不履行网络安全保护义务被处罚

今年6月至7月间，山西省直事业单位网站存在SQL注入漏洞，严重影响网站信息安全，连续被国家网络与信息安全通报中心通报。根据《中华人民共和国网络安全法》第二十一条第二款之规定，网络运营者应当按照网络安全等级保护制度的要求，采取防范计算机病毒和网络攻击、网络侵入等危害网络安全行为的技术措施；第五十九条第一款之规定，网络运营者不履行第二十一条规定的网络安全保护义务的，由有关主管部门责令改正，依法予以处罚。山西省网安总队认为该单位的行为已违反《网络安全法》相关规定，忻州市、县两级公安机关网安部门对该单位进行了现场执法检查，依法给予行政处罚并责令其改正。

执法机构：山西省忻州市、县两级公安机关网安部门

处罚行为：未按照网络安全等级保护制度的要求，采取防范计算机病毒和网络攻击、网络侵入等危害网络安全行为的技术措施

处罚措施：警告并责令其改正

法律依据：《网络安全法》第21条、第59条

### 政府事业单位违法案例

### 国内教育行业违法案例

## 怀远一学校网站未履行网络安全保护义务 分管副县长被约谈

8月12日，蚌埠怀远县教师进修学校网站因网络安全等级保护制度落实不到位，遭黑客攻击入侵。蚌埠市公安局网安支队调查案件时发现，该网站自上线运行以来，始终未进行网络安全等级保护的定级备案、等级测评等工作，未落实网络安全等级保护制度，未履行网络安全保护义务。根据《网络安全法》第五十六条之规定，省公安厅网络安全保卫总队约谈怀远县教师进修学校法定代表人、怀远县人民政府分管副县长。这是自《网络安全法》实施以来，首次由省级人民政府公安部门履行网络安全监督管理职责，约谈网络运营者的法定代表人及相关责任人。

蚌埠市局网安支队依法对网络运营单位怀远县教师进修学校处以一万五千元罚款，对负有直接责任的副校长处以五千元罚款。

近日，重庆永川公安经核发现，某私立医院因未按照网络安全等级保护制度的要求履行安全保护义务造成业务瘫痪——医院 HIS、LIS、PACS 和 EMR 等后台系统业务以及医院网站等主要系统业务全部放置在同一套服务器中，未安装边界防护设备、未安装日志行为审计设备、未设置数据安全备份策略等其他的网络安全技术措施，使得黑客可以通过互联网攻破医院系统后植入勒索病毒，导致医院业务停摆。

针对此案，公安部门对医院按照《中华人民共和国网络安全法》第五十九条之规定，对医院处以罚款一万元，对直接负责的主管人员处以罚款五千元行政处罚。

### 医疗行业违法案例

### 企业单位违法案例

## 事件3：汕头某公司未及时履行网络安全义务，网警依据网安法责令改正

2017年7月20日，广东汕头网警支队在对该市网络安全等级保护重点单位进行执法检查时发现，汕头市某信息科技有限公司于2015年11月向公安机关报备的信息系统安全等级为第三级，经测评合格后投入使用，但2016年至今未按规定定期开展等级测评。

该公司之行为已违反《信息安全等级保护管理办法》第十四条第一款和网络安全法第二十一条（五）项规定，未按规定履行网络安全等级测评义务。根据网络安全法第五十九条规定，广东汕头网警支队依法对该单位给予警告处罚并责令其改正。

发布于：

[http://www.thepaper.cn/newsDetail\\_forward\\_1765140/](http://www.thepaper.cn/newsDetail_forward_1765140/)

执法机构：广东汕头网警支队

处罚行为：未按规定履行网络安全等级测评义务

处罚措施：警告并责令其改正

法律依据：《网络安全法》第21条、第59条第1款

# 等级保护

---

国家信息安全保障的基本制度、基本策略，保护信息化发展、维护信息安全的基本保障

# 什么是等级保护？

网络安全等级保护是指对国家重要信息、法人和其他组织及公民的专有信息以及公开信息和存储、传输、处理这些信息的信息系统**分等级实行安全保护**，对信息系统中使用的信息安全产品实行**按等级管理**，对信息系统中发生的信息安全事件**分等级响应、处置**。



# 国家等级保护制度进入 2.0 时代

- 中央关于加强社会治安防控体系建设的意见、公安改革若干重大问题的框架意见（2015年）要求“健全完善信息安全等级保护制度”
- 习近平总书记等中央领导批示要求：健全完善以保护国家关键信息基础设施安全为重点的网络安全等级保护制度。
- 相较于2007年实施的《信息安全等级保护管理办法》所确立的等级保护1.0体系，为了适应现阶段网络安全的新形势、新变化以及新技术、新应用发展的要求，2018年公安部正式发布《网络安全等级保护条例（征求意见稿）》，国家对信息安全技术与网络安全保护迈入2.0时代。
- 公安部发布《贯彻落实网络安全等级保护制度和关键信息基础设施安全保护制度的指导意见》（公网安[2020]1960号）

## 中华人民共和国公安部

公网安〔2020〕1960号

### 关于印送《贯彻落实网络安全等级保护制度和关键信息基础设施安全保护制度的指导意见》的函

中央和国家机关各部委，国务院各直属机构、办事机构、事业单位，各中央企业：

为深入贯彻党中央有关文件精神 and 《网络安全法》，指导重点行业、部门全面落实网络安全等级保护制度和关键信息基础设施安全保护制度，健全完善国家网络安全综合防控体系，有效防范网络安全威胁，有力处置重大网络安全事件，配合公安机关加强网络安全监管，严厉打击危害网络安全的违法犯罪活动，切实保障关键信息基础设施、重要网络和数据安全，公安部研究制定了《贯彻落实网络安全等级保护制度和关键信息基础设施安全保护制度的指导意见》。现印送给你们，请结合本行业、本部门工作实际，认真参照执行。



2019年5月13日，等保2.0相关的《信息安全技术网络安全等级保护基本要求》、《信息安全技术网络安全等级保护测评要求》、《信息安全技术网络安全等级保护安全技术要求》等国家标准正式发布，并于2019年12月1日开始实施。

# 哪些行业需要开展等级保护工作？



# 等级保护制度与关键信息基础设施保护的关系

## 网络安全等级保护制度是关键信息基础设施保护的基础，关键信息基础设施是等级保护制度的保护重点

- 关键信息基础设施的范围应该在定级备案的第三级（含）以上的保护对象中确定，并首先要落实第三级以上的安全防护技术和管理措施
- 关键信息基础设施必须按照等级保护制度要求，开展定级备案、等级测评、安全建设整改、安全检查等强制性、规定性工作

第二条 本条例所称关键信息基础设施，是指公共通信和信息服务、能源、交通、水利、金融、公共服务、电子政务、国防科技工业等重要行业和领域的，以及其他一旦遭到破坏、丧失功能或者数据泄露，可能严重危害国家安全、国计民生、公共利益的重要网络设施、信息系统等。

# 构建新的标准体系

《 信息安全技术 网络安全等级保护实施指南 》 GB/T 25058-2019

《 信息安全技术 网络安全等级保护定级指南 》 GB/T 22240

《 信息安全技术 网络安全等级保护基本要求 》 GB/T 22239-2019

《 信息安全技术 网络安全等级保护安全设计要求 》 GB/T 25070-2019

《 信息安全技术 网络安全等级保护测评要求 》 GB/T 28448-2019

《 信息安全技术 网络安全等级保护测评过程指南 》 GB/T 28449-2018



# 实施等级保护的意义

明确责任和工作方法，  
让安全防护更加规范



提高安全思路 and 意识，  
合理分配网络安全投资

改变以往单点防御方式，  
让安全建设更加体系化

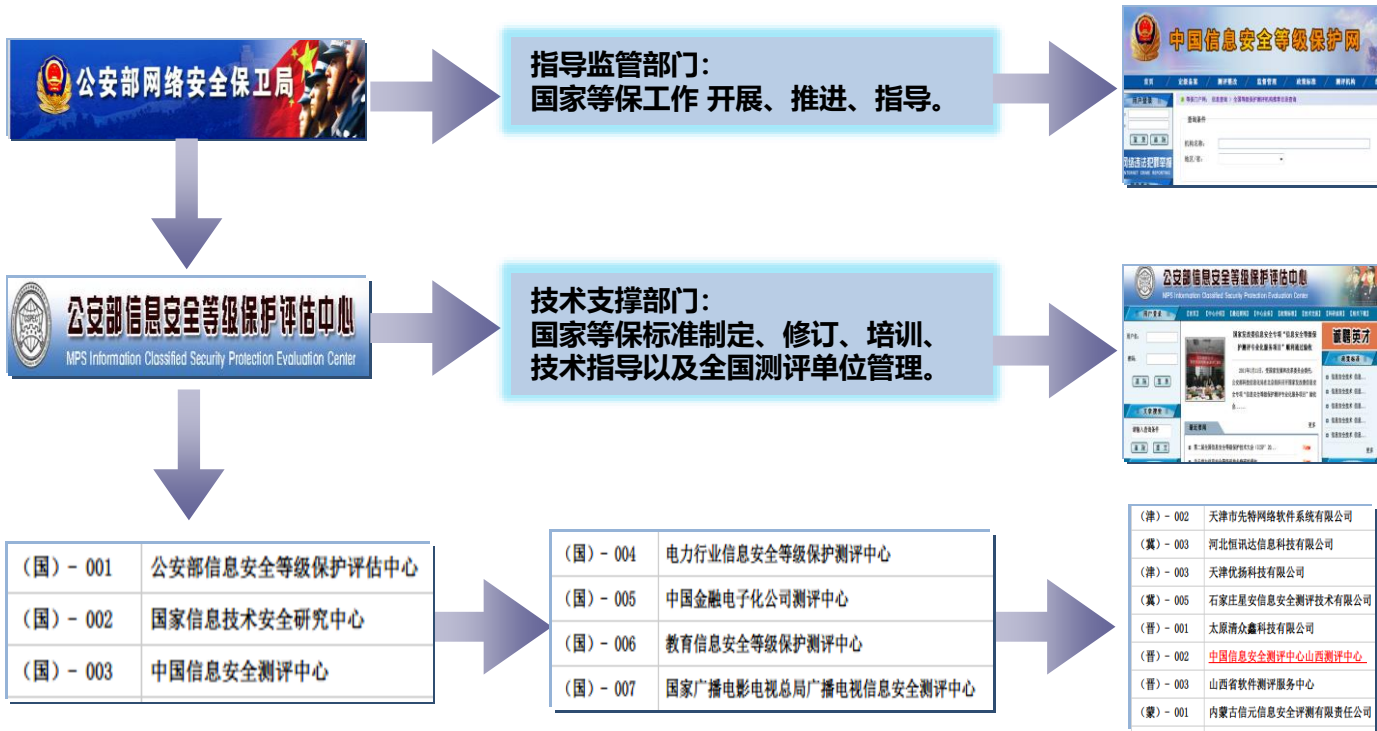




# 等级保护工作流程

定级备案，建设整改，等级测评

# 等级保护管理组织



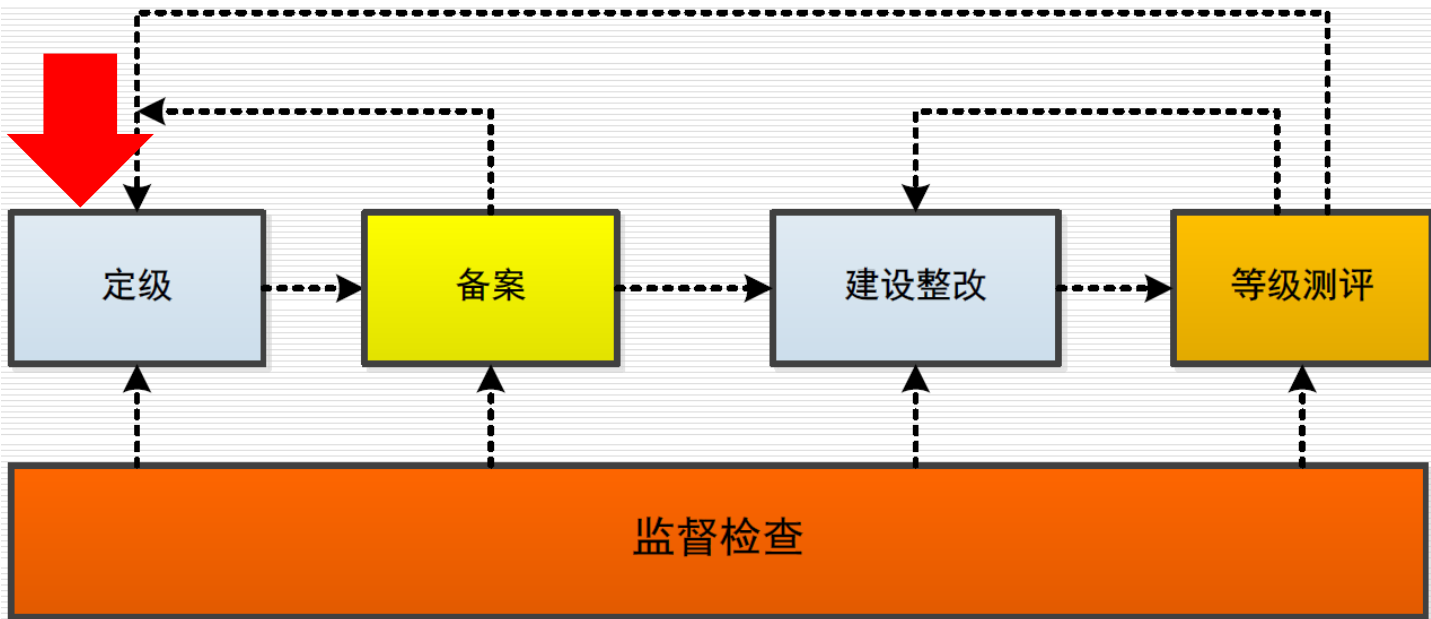
国家测评机构

行业测评机构

地方测评机构

# 等级保护有“五个规定动作”

网络安全等级保护工作包括定级、备案、建设整改、等级测评、监督检查五个阶段。



**监督检查是保护能力不断提高的保障**

# 等级保护主要工作流程

## 测评周期（依据信息安全等级保护管理办法）

第二级： 每2年测评一次      第三级： 每年至少一次      第四级： 每半年至少一次      第五级： 依据特殊安全需求测评

### 等级保护工作实施流程内容

|              |                                                                                                                                                                                                                                                                                                         |                          |
|--------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
| 备案资料准备       | 定级报告、备案表、网络与信息安全承诺书、网络安全等级保护应急联系登记表、专家评审意见、相关证件原件扫描件等其他备案材料(根据各区分局需要备案材料情况而定)。(以上准备纸质材料是用于去领取备案证明时候提交给公安)                                                                                                                                                                                               | 5个工日左右<br>(看案单位配快慢)      |
| 专家定级评审会      | 邀请三位专家就信息系统定级情况组织开展定级评审会议，论证信息系统定级的合理性，以及相关备案材料的修改和确定。最终专家签字专家评审意见。                                                                                                                                                                                                                                     | 一个工作日                    |
| 线上提交备案材料进行备案 | 备案单位可通过互联网使用浏览器访问等保备案预约平台<br><a href="https://211.101.21.196:3344">https://211.101.21.196:3344</a> ，注册申请本单位账号!注册信息待公安审核几个工作日，下发VPN软件下载地址及登录账号和密码!<br>通过“查询注册结果”功能查询注册信息审核情况，如公安机关“审核通过”登录vpn相关账号和密码!点击备案申请填写备案信息及提交相关备案材料上传后，待公安对备案材料进行审核，审核通过后待公安通知领取备案证明时间，同时提交纸质版备案材料。领取备案证明后电子版发给测评机构，测评机构办理入场测评登记。 | 不定<br>(看公安审核快慢，一般10个工作日) |
| 差距分析（初测）     | 依据等级保护测评要求开展等级保护测评工作及漏洞扫描、渗透测试等(初测)出具差距分析报告及整改意见                                                                                                                                                                                                                                                        | 10个工作日左右                 |
| 安全整改         | 备案单位依据整改并结合企业的自身情况进行信息系统整改                                                                                                                                                                                                                                                                              | 不定(看备案单位整改快慢)            |
| 等级测评         | 依据等级保护测评要求开展等级保护测评工作(复测)                                                                                                                                                                                                                                                                                | 7个工作日左右                  |
| 测评报告         | 测评机构进行等级测评报告编制、出具                                                                                                                                                                                                                                                                                       | 15个工作日左右                 |
| 提交测评报告       | 测评机构把测评报告盖章后给备案单位，备案单位提交给网安大队。整条项目结束。                                                                                                                                                                                                                                                                   | 10个工作日左右                 |

# 重要行业关键信息系统划分及定级建议

国家信息安全等级保护坚持自主定级、自主保护的原则。

| 保护对象级别 | 重要性程度         | 监督管理强度等级 |
|--------|---------------|----------|
| 第一级    | 一般系统          | 自主保护级    |
| 第二级    | 一般系统          | 指导保护级    |
| 第三级    | 重要系统/关键信息基础设施 | 监督保护级    |
| 第四级    | 关键信息基础设施      | 强制保护级    |
| 第五级    | 关键信息基础设施      | 专控保护级    |

信息系统的安全保护等级应当根据信息系统在国家安全、经济建设、社会生活中的重要程度，信息系统遭到破坏后对国家安全、社会秩序、公共利益以及公民、法人和其他组织的合法权益的危害程度等因素确定。

# 重要行业关键信息系统划分及定级建议

| 等级  | 对象     | 侵害客体      | 侵害程度   | 监管强度   |
|-----|--------|-----------|--------|--------|
| 第一级 | 一般系统   | 合法权益      | 损害     | 自主保护   |
| 第二级 |        | 合法权益      | 严重损害   | 指导     |
|     |        | 社会秩序和公共利益 | 损害     |        |
| 第三级 | 重要系统   | 社会秩序和公共利益 | 严重损害   | 监督检查   |
|     |        | 国家安全      | 损害     |        |
| 第四级 |        | 社会秩序和公共利益 | 特别严重损害 | 强制监督检查 |
|     |        | 国家安全      | 严重损害   |        |
| 第五级 | 极端重要系统 | 国家安全      | 特别严重损害 | 专门监督检查 |

# 定级实例

| 等级          | 等级定义                                                         | 适用系统                |
|-------------|--------------------------------------------------------------|---------------------|
| 第一级<br>自主保护 | 信息系统受到破坏后，会对公民，法人和其他组织的合法权益造成损害，但不损害国家安全，社会秩序和公共利益。          | 个人博客等               |
| 第二级<br>指导保护 | 信息系统受到破坏后，会对公民，法人和其他组织的合法权益产生严重损害，或者对社会秩序和公共利益造成损害，但不损害国家安全。 | 普通网站，小门户等           |
| 第三级<br>监督保护 | 信息系统受到破坏后，会对公民，法人和其他组织的合法权益产生严重损害，或者对国家安全造成损害。               | 用户量较大的系统，存储有敏感信息的系统 |
| 第四级<br>强制保护 | 信息系统受到破坏后，会对公民，法人和其他组织的合法权益产生严重损害，或者对国家安全造成严重损害。             | 银行核心电力调度等           |
| 第五级<br>专控保护 | 信息系统受到破坏后，会对公民，法人和其他组织的合法权益产生严重损害，会对国家安全造成特别严重损害。            |                     |

# 定级对象

也称等级**保护对象**、网络安全等级保护工作的作用对象

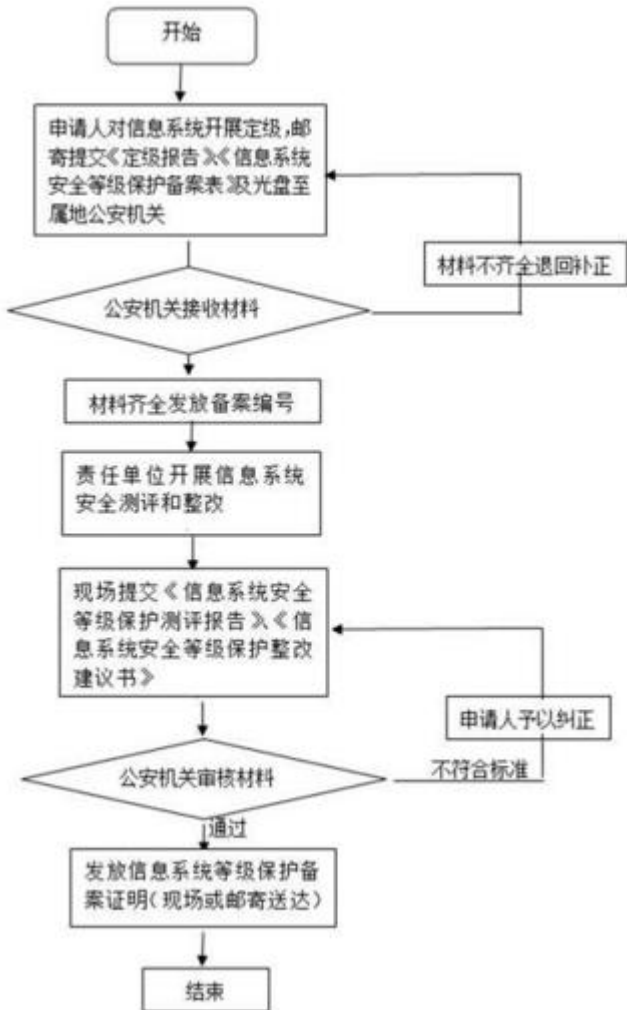
包括**网络基础设施**（广电网、电信网、专用通信网络等）、云计算平台系统、大数据平台系统、物联网、工业控制系统、采用移动互联技术的系统等。



## 备案的依据

- 《信息安全等级保护备案实施细则》（公信安【2007】1360号）
- 注意：将会根据网络安全等级保护条例进行调整

## 备案的流程



运营、使用单位在确定等级后到所在地的市级及以上公安机关备案。

- 新建二级及以上信息系统在投入运营后30日内、已运行的二级及以上信息系统在等级确定30日内备案。
- 公安机关对信息系统备案情况进行审核，对符合要求的在10个工作日内颁发等级保护备案证明。
- 对于定级不准的，应当重新定级、重新备案。对于重新定级的，公安机关一般会建议备案单位组织专家进行重新定级评审，并报上级主管部门审批。

# 备案地点

## 二级以上信息系统

由信息系统运营使用单位(备案单位)到**地市级以上公安机关网络安全保卫部门** 办理备案手续,填写《信息系统安全等级保护备案表》。

## 隶属于省级的备案单位

其跨地(市)联网运行的信息系统,由**省级公安机关网络安全保卫部门**受理备案。

## 隶属于中央的在京单位

其跨省或者全国统一联网运行并由主管部门统一定级的信息系统,由主管部门向**公安部**备案。

## 跨省或者全国统一联网运行的信息系统

**在各地运行、应用的分支系统**,由所在地地市级以上公安机关网络安全保卫部门受理备案。

## 各部委统一定级信息系统在各地的分支系统

即使是上级主管部门定级的,也要到当地公安网络安全保卫部门备案。

# 信息系统安全等级保护备案表

- 1、单位基本情况
- 2、信息系统情况
- 3、信息系统定级情况
- 4、第三级以上信息系统提交材料情况

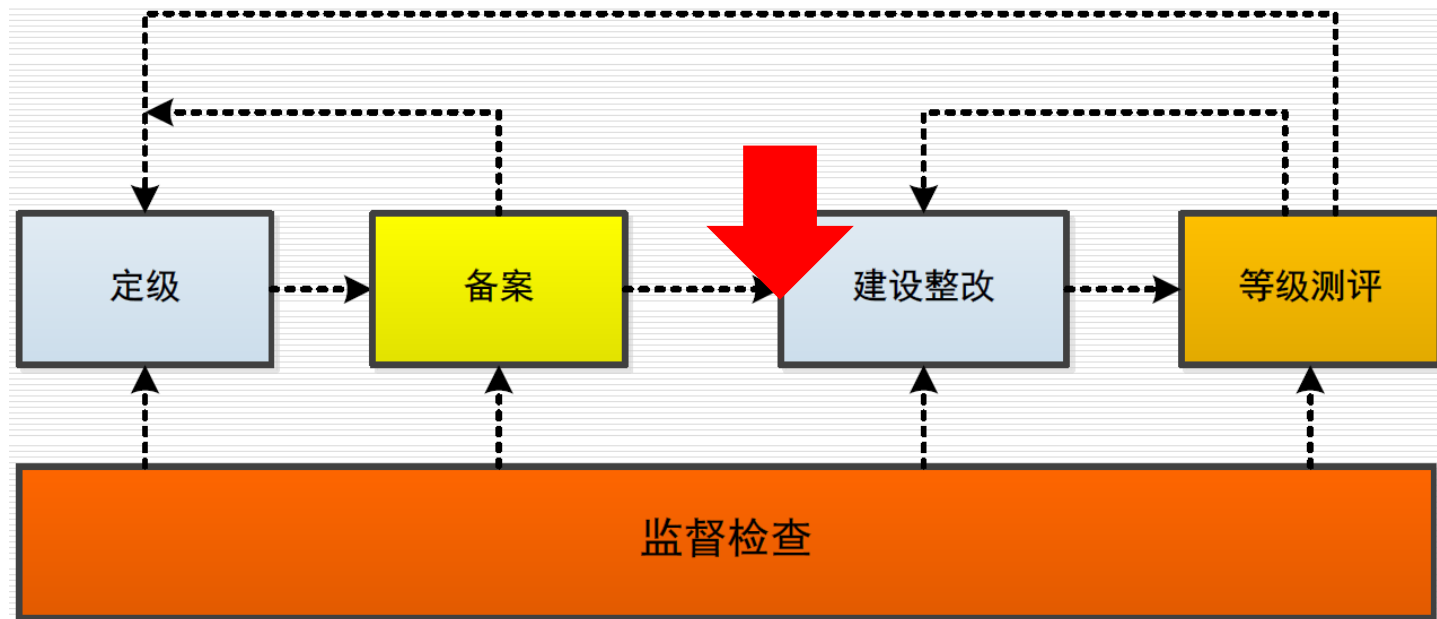
# 公安机关受理备案

公安机关受理备案，按照《信息安全等级保护备案实施细则》要求，对备案材料进行审核，定级准确、材料符合要求的颁发由公安部统一监制的**备案证明**。

# 定级备案基本流程总结

- 1、 用户初步定级
- 2、 编写定级报告
- 3、 专家定级评审
- 4、 填写备案表
- 5、 提交备案材料
- 6、 收到备案证明

## 等级保护有“五个规定动作”



使确定了等级的信息系统能够达到相应等级的基本保护水平和满足自身需求的安全保护能力。

# 建设整改使用的标准

运营使用单位按照管理规范和技术标准，选择管理办法要求的信息安全产品，建设符合等级要求的信息安全设施，建立安全组织，制定并落实安全管理制度。

对于未达到安全等级保护要求的，运营、使用单位应当进行整改。整改完成应当将整改报告报公安机关备案。

## □ 《网络安全等级保护基本要求》

■ GB/T22239-2019

## □ 《网络安全等级保护设计技术要求》

■ GB/T25070-2019



# 《网络安全等级保护基本要求》GB/T 22239 2019

## 《基本要求》文本结构

由 10 个章节 8 个附录构成

1. 范围
2. 规范性引用文件
3. 术语定义
4. 缩略语
5. 网络安全等级保护概述

### 6-10 五个等级的安全要求

附录A 安全要求的选择和使用

附录B 关于等级保护对象整体安全保护能力的要求

附录C 等级保护安全框架和关键技术使用要求

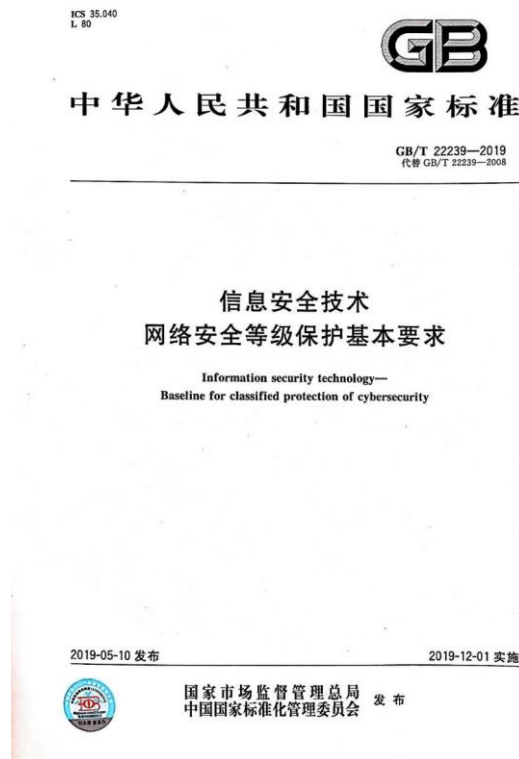
附录D 云计算应用场景说明

附录E 移动互联应用场景说明

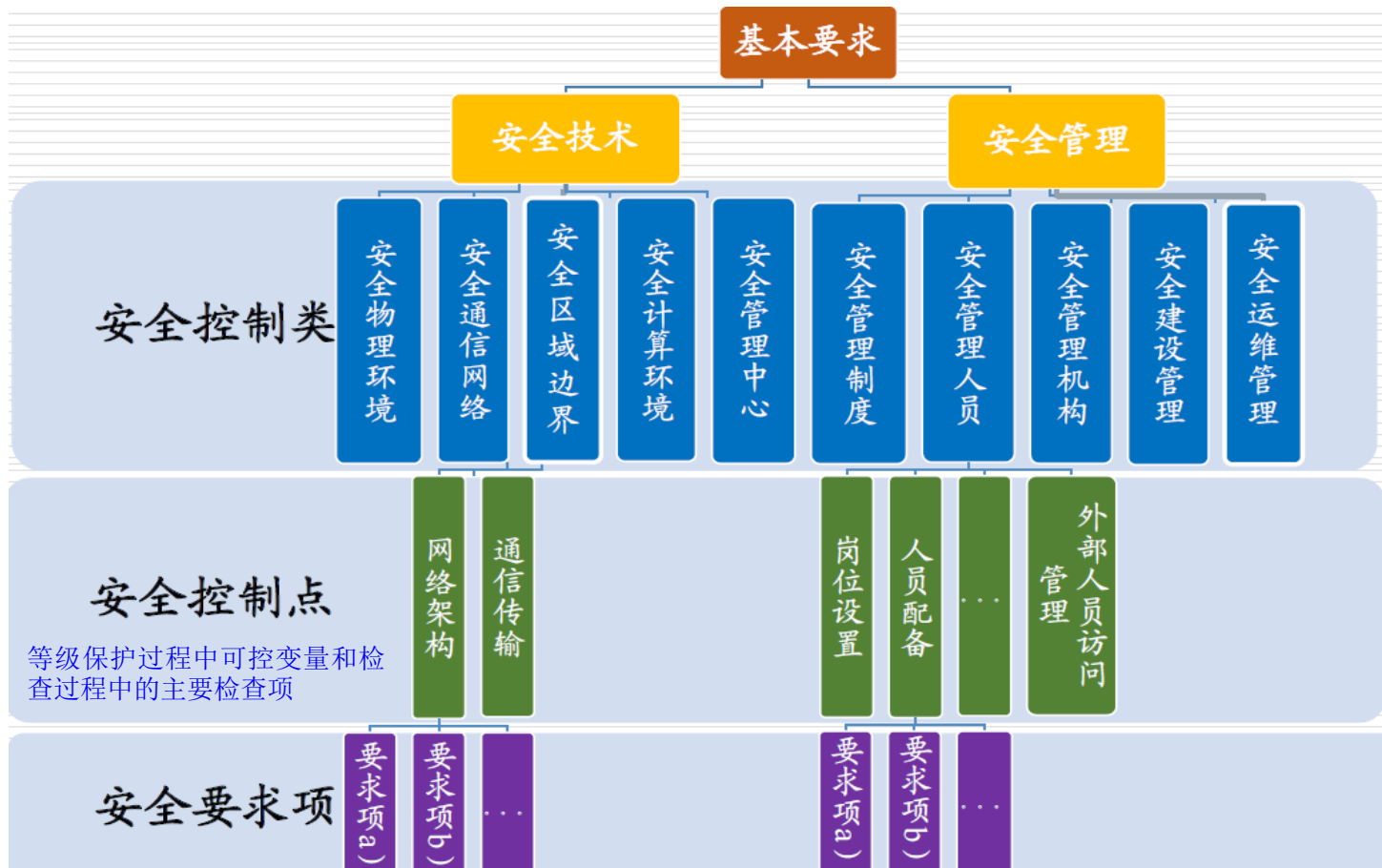
附录F 物联网应用场景说明

附录G 工业控制系统应用场景说明

附录H 大数据应用场景说明



# 《基本要求》文本描述框架



# 《网络安全等级保护基本要求》GB/T 22239-2019

## 某级安全要求

安全通用要求

云计算安全扩展要求

移动互联安全扩展要求

物联网安全扩展要求

工业控制系统安全扩展要求

## 章节示例:

8 第三级安全要求

8.1 安全通用要求

8.2 云计算安全扩展要求

8.3 移动互联安全扩展要求

8.4 物联网安全扩展要求

8.5 工业控制系统安全扩展要求

# 增加云计算安全扩展要求

云计算安全扩展要求章节针对云计算的特点提出特殊保护要求。对云计算环境主要增加的内容包括“基础设施的位置”、“虚拟化安全保护”、“镜像和快照保护”、“云服务商选择”和“云计算环境管理”等方面。

## 云计算安全扩展要求原则性要求

- ① 应确保云计算平台不承载高于其安全保护等级的业务应用系统。
- ② 应确保云计算基础设施位于中国境内。
- ③ 云计算平台的运维地点应位于中国境内，如需境外对境内云计算平台实施运维操作应遵循国家相关规定。
- ④ 云计算平台运维过程产生的配置数据、鉴别数据、业务数据、日志信息等存储于中国境内，如需出境应遵循国家相关规定。

## 主要技术思想

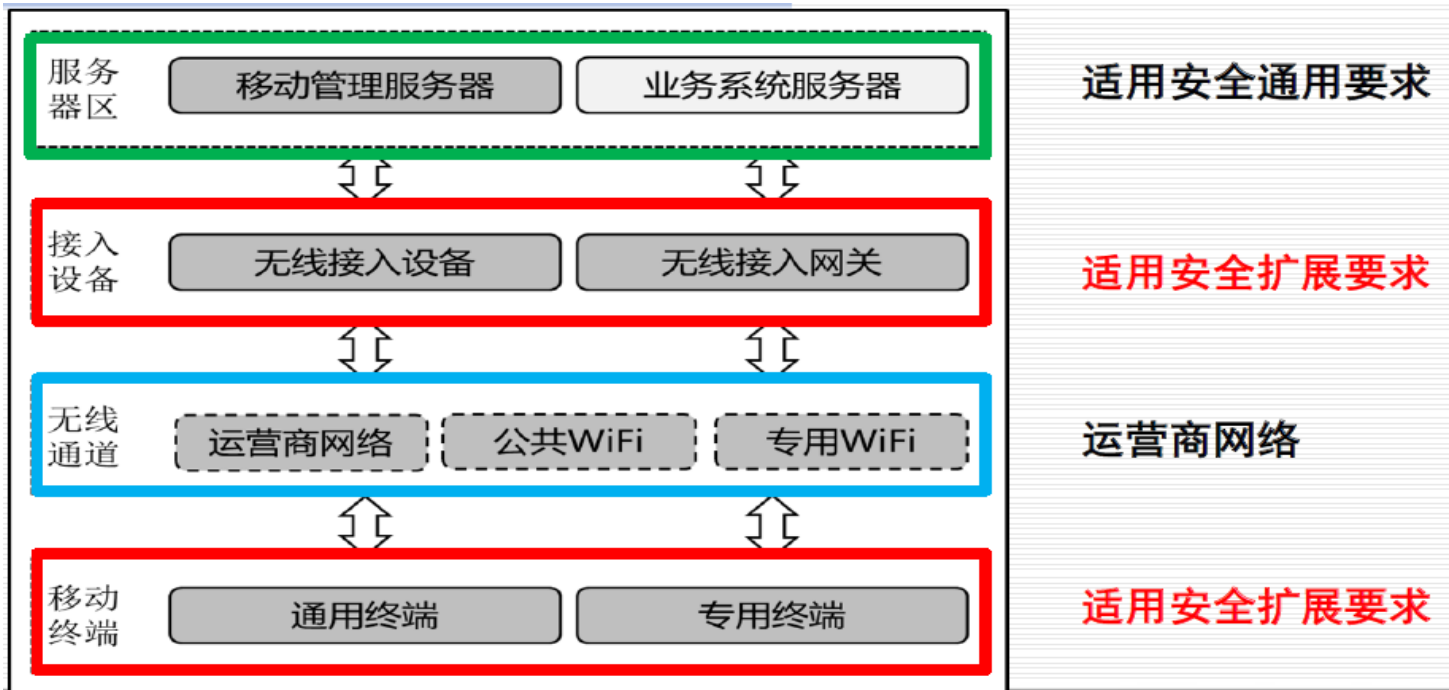
- 云计算平台（采用云计算技术的系统）自身安全防护要求。
- 云计算平台向其上租户系统提供安全防护的能力要求。

### 网络架构

c) 应具有根据云服务客户业务需求提供通信传输、边界防护、入侵防范等安全机制的能力;

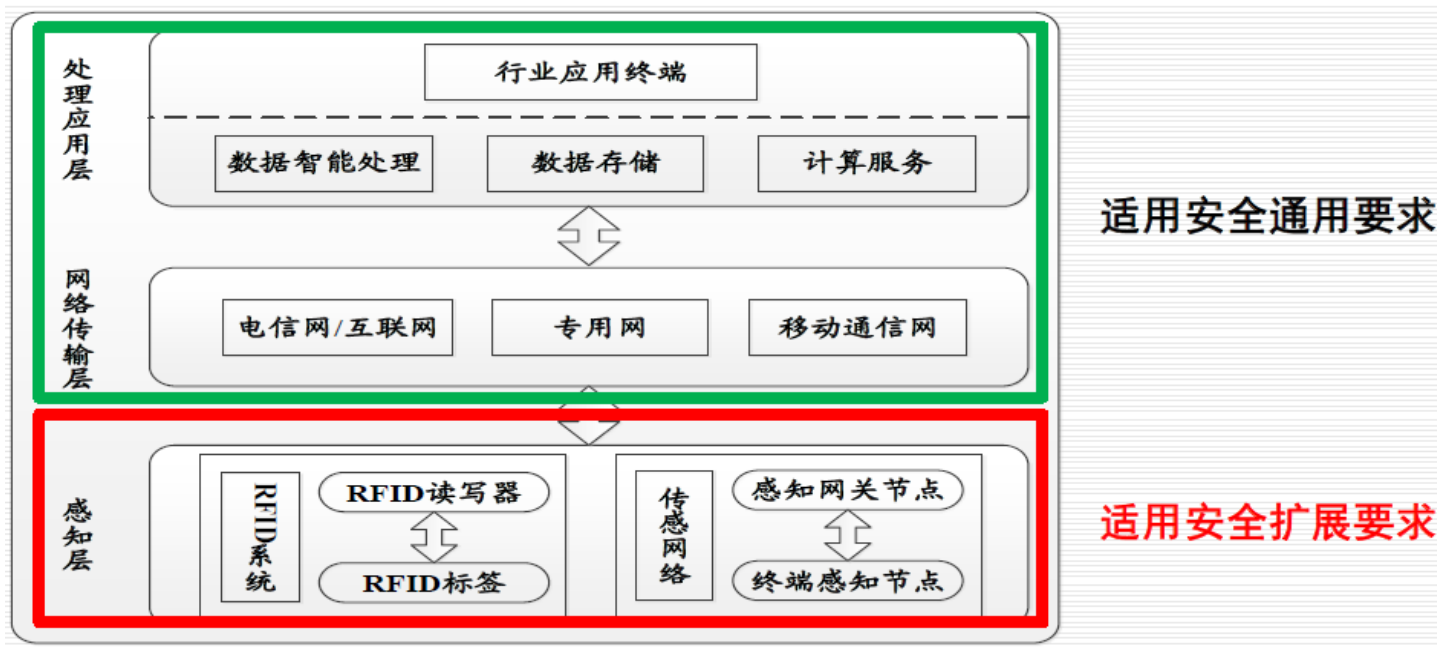
# 增加移动互联安全扩展要求

移动互联安全扩展要求章节针对移动互联的特点提出特殊保护要求。对移动互联环境主要增加的内容包括“无线接入点的物理位置”、“移动终端管控”、“移动应用管控”、“移动应用软件采购”和“移动应用软件开发”等方面。



# 增加物联网安全扩展要求

物联网安全扩展要求章节针对物联网的特点提出特殊保护要求。对物联网环境主要增加的内容包括“感知节点的物理防护”、“感知节点设备安全”、“感知网关节点设备安全”、“感知节点的管理”和“数据融合处理”等方面。



# 工业控制系统安全扩展要求使用要点

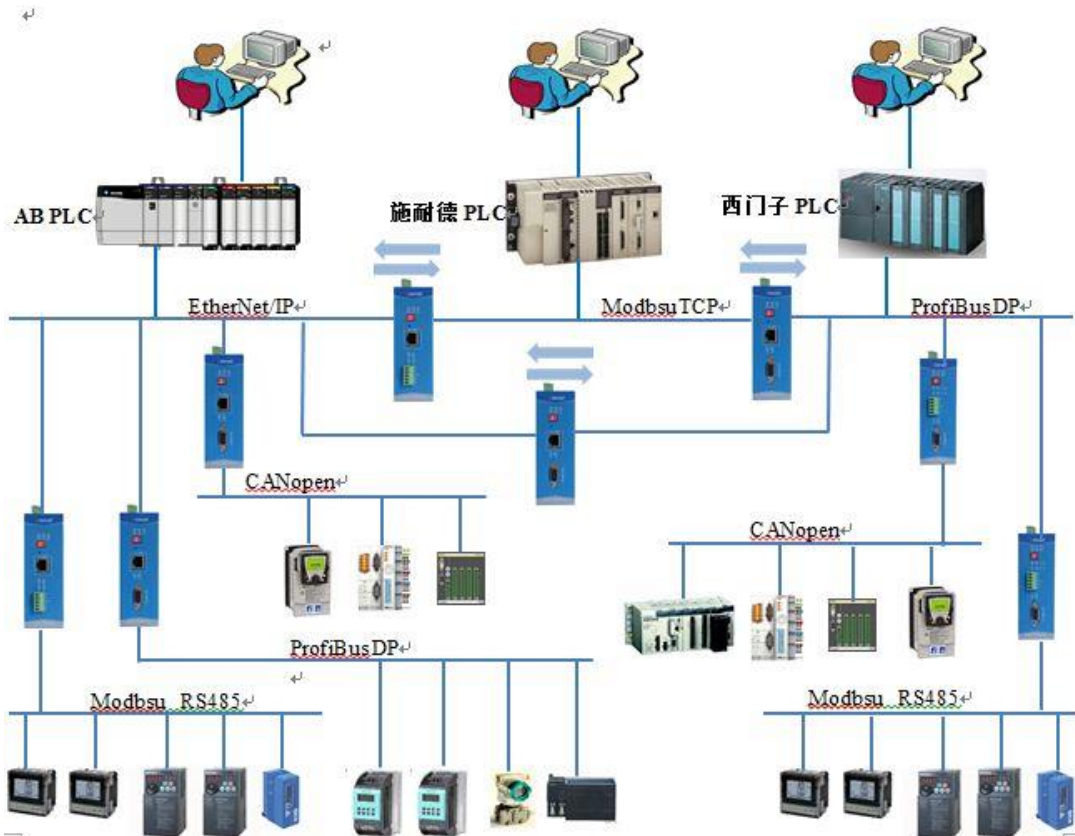
- 工业控制系统安全扩展要求主要针对现场控制层和现场设备层提出特殊安全要求，其他层次使用安全通用要求条款。
- 对工业控制系统的保护需要根据实际情况使用基本要求，具体安全通用要求和安全扩展要求的使用方法比较复杂。



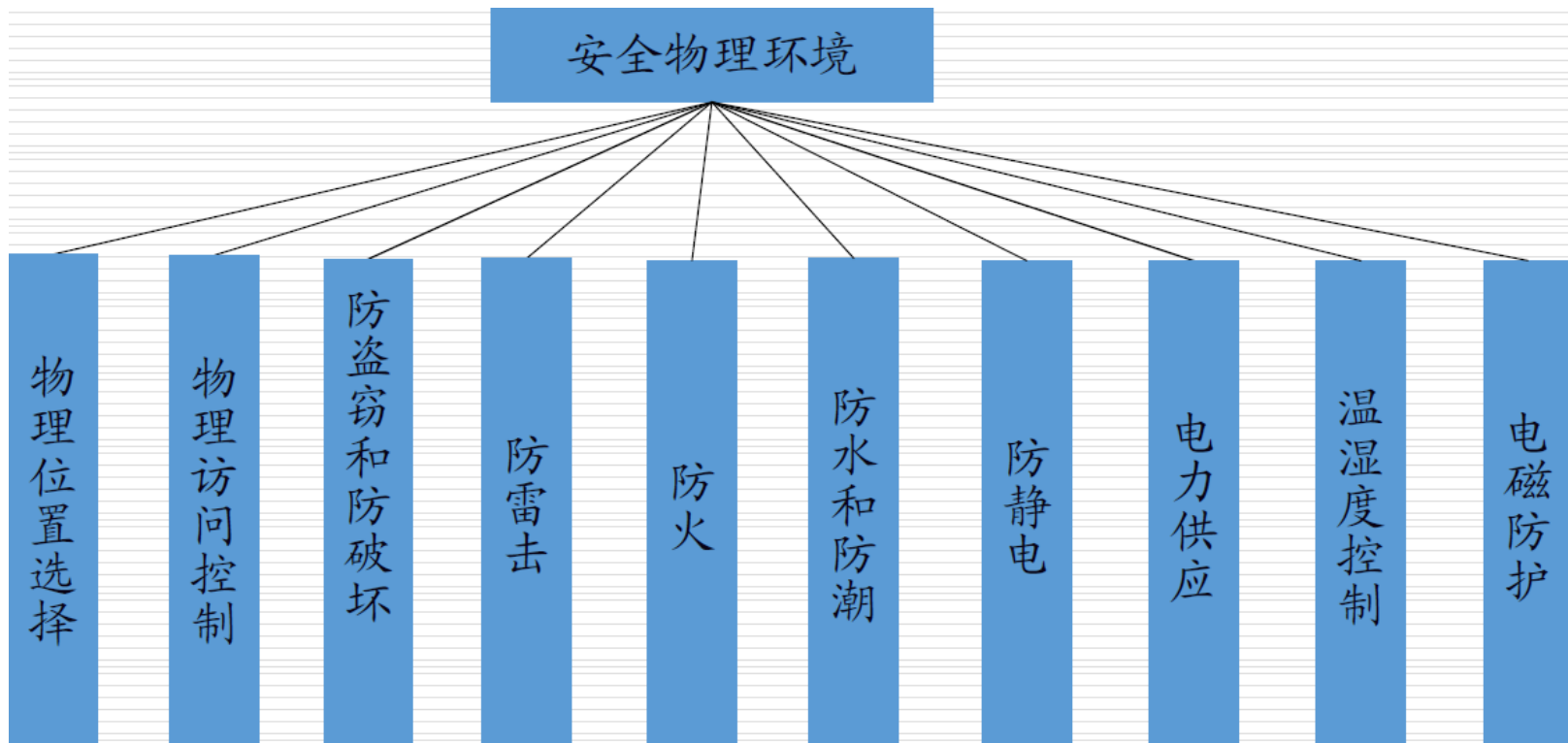
# 增加工业控制系统安全扩展要求

工业控制系统安全扩展要求章节针对工业控制系统的特点提出特殊保护要求。

工业控制系统主要增加的内容包括“室外控制设备防护”、“工业控制系统网络架构安全”、“拨号使用控制”、“无线使用控制”和“控制设备安全”等方面，针对工业控制系统实时性要求高的特点调整了“漏洞和风险管理”和“恶意代码防范管理”方面的要求。



# 1、安全物理环境



# Summary of The Class



- 等保的强制性：法律规定
- 等保的流程：定级备案+建设整改+等级测评
  - 具体任务
  - 依据的标准
  - 执行者和审批单位
- 适当关注新旧标准的对照